

Автор: Шон Майкл Кернер

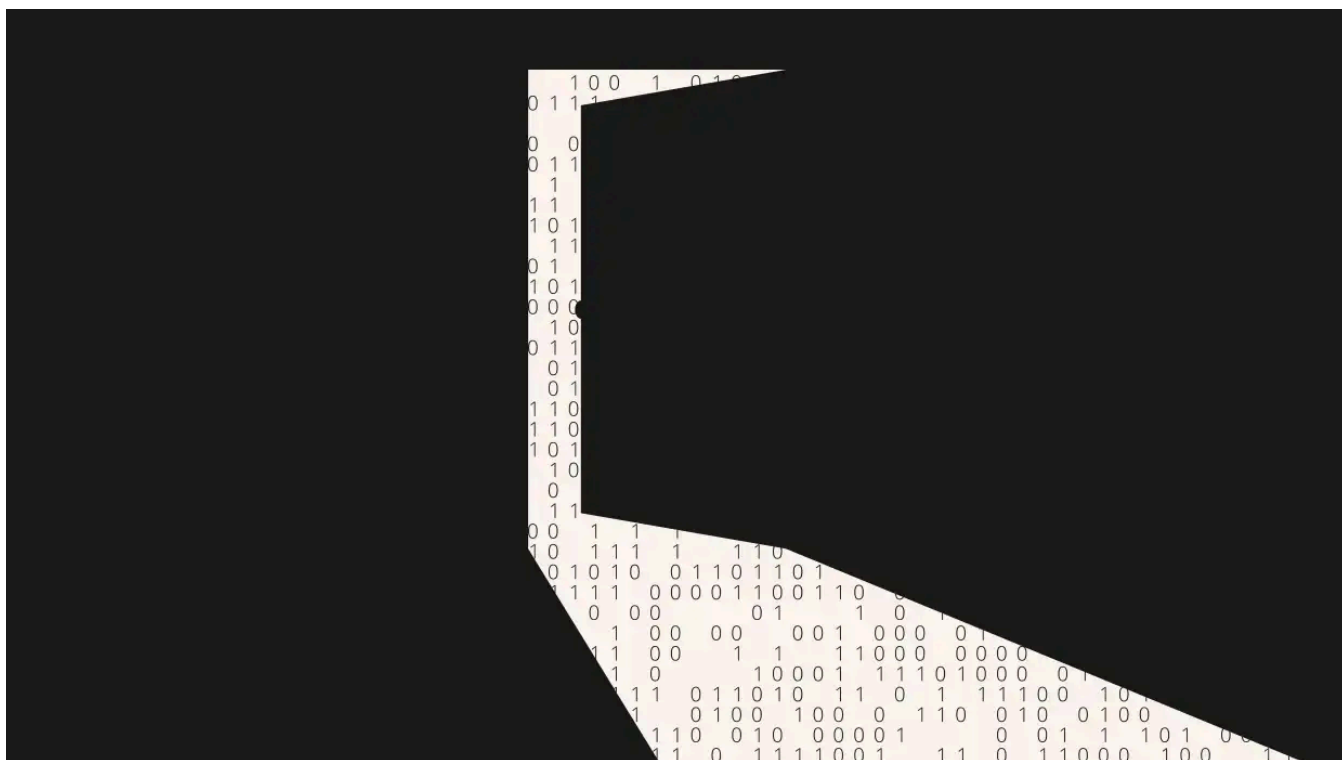
Автор, Вносящий свой вклад

С глаз долой — из сердца вон: исследование DEF CON называет IPMI «санкционированным бэкдором» в корпоративные сети

Новости

10 августа 2026 года • 6 минут

Одновременно с публикацией информации runZero выпустила OOBscan — инструмент с открытым исходным кодом, который сканирует уязвимые BMC и другие устройства внеполосного управления.



Источник: Serg001 / Shutterstock

Почти в каждом сервере есть потенциальный бэкдор, который может поставить под угрозу корпоративную сеть.

Контроллеры управления плинтусами, или BMCs, - это аппаратные средства, встроенные в серверные материнские платы, которые обеспечивают удаленное управление питанием, доступ к консоли и обновления встроенного программного обеспечения независимо от операционной системы хоста. IPMI - это протокол, наиболее часто используемый для связи с ними.

На конференции **DEF CON 34** [<https://defcon.org/html/defcon-34/dc-34-index.html>] исследователь в области безопасности **Х. Д. Мур** [<https://www.linkedin.com/in/hdmoore/>], соучредитель компании runZero, рассказал о множестве уязвимостей на этом уровне, которые в основном не были устранены. Среди них — HPE iLO, Supermicro IPMI, Dell iDRAC 10 и проект с открытым исходным кодом OpenBMC. Согласно презентации Мура, всего было выявлено 123 подтверждённые уязвимости, которые были объединены в 35 черновых рекомендаций для восьми производителей. Мур следил за безопасностью BMC с тех пор, как в 2013 году Дэн Фармер опубликовал исследование о раскрытии паролей IPMI. В этом году выяснилось, что ситуация скорее ухудшилась, чем улучшилась. Некоторые из уязвимых устройств оснащены графическими процессорами стоимостью в миллион долларов, доступ к которым осуществляется через веб-интерфейс без пароля.

«По сути, это устройства, которые представляют собой санкционированный бэкдор для любого реального оборудования», — сказал Мур на своей сессии в рамках конференции DEF CON.



Скриншот выступления Х. Д. Мура на DEF CON 34.

Credit: Шон Майкл Кернер

Как становятся доступными порты управления

Многие серверы поставляются с одним физическим сетевым портом, который используется совместно хостом и системой управления и мониторинга. Если конфигурация устройства сбрасывается или возникает ошибка контрольной суммы, система управления и мониторинга может получить собственный адрес через DHCP в любой подсети, к которой подключен порт.

«Обычно это происходит из-за того, что кто-то ошибся и выдал неправильный IP-адрес», — сказал Мур, объясняя, почему исследователи продолжают находить десятки тысяч таких контроллеров [подключенных к открытому интернету \[https://www.networkworld.com/article/4202570/a-13-year-old-flaw-is-exposing-tens-of-thousands-of-data-center-management-systems-2.html\]](https://www.networkworld.com/article/4202570/a-13-year-old-flaw-is-exposing-tens-of-thousands-of-data-center-management-systems-2.html).

Обнаружение устройств по всему интернету с помощью IPMI-зондов во всем диапазоне IPv4 и запросов к Shodan выявило около 51 000 устройств, отвечающих на запросы IPMI. От 23 000 до 25 000 из них выдали хеши паролей, которые можно взломать без аутентификации. При опросе клиентов runZero выяснилось, что уязвимость не уменьшилась, а увеличилась, поскольку эти сети никогда не предназначались для сканирования извне.

Новое исследование также изменило представление о том, насколько легко взломать эти устройства. До этой работы примерно к 12% BMC во внутренних сетях можно было получить доступ без взлома. После того как Мур рассказал о новых уязвимостях на конференции DEF CON, этот показатель вырос примерно до 33%. На устройствах, подключенных к интернету, доля устройств, которые можно легко взломать, увеличилась с 8% до 21%. Как только злоумышленник проникает в систему через BMC, собственная защита сервера перестает иметь значение.

“It doesn’t really matter how secure your server is,” Moore said.

What an attacker can reach

Several of the bugs Moore presented start with no credentials at all. They end with code execution on the host server, not just the BMC. The research grouped the underlying flaws into a handful of recurring classes:

- **RAKP state-transition bugs.** RAKP, the Remote Authentication Key-Exchange Protocol, is the challenge-response handshake IPMI 2.0 uses to authenticate a session. Skipping or reordering its steps lets an attacker authenticate against leftover data sitting in memory.
- **Type confusion.** A session started in one authentication mode ends up reusing credentials that were meant for a different mode.
- **Vendor-specific backdoor modes.** Supermicro added a hardcoded password meant to stop password hash leaks, and the fix became a bypass of its own.
- **Session relabeling.** Two sessions sharing the same identifier can be used to escalate a low-privilege account to an administrator.
- **Integrity and encryption bypass.** A device accepts unencrypted commands even after both sides negotiated a cipher suite that was supposed to require them.

While multiple IPMI implementations are at risk, Moore specifically called out the OpenBMC project.

OpenBMC is the shared open-source firmware project used across Supermicro’s newest generation, Nvidia BlueField, Intel, Google and other hyperscalers. Because the code is shared, a bug in the authentication flow does not stay contained to one vendor. It reaches every product built on that codebase at once. The flaw lets an attacker authenticate as any user by deliberately setting an invalid privilege level during the handshake, which causes the session to fall back on a default key built into OpenBMC’s own code instead of the real password.

What network teams should do

While IPMI is vulnerable to multiple exploits, there are things that network teams can do to limit the risk.

- **Segment management traffic.** Putting BMC traffic on its own VLAN keeps pre-authentication flaws from reaching past one network segment.

- **Use a dedicated management NIC.** A shared port puts the BMC on the same switch port and access list as the production server, raising the odds of accidental exposure.
- **Disable KCS where it is not needed.** KCS, or Keyboard Controller Style, is an in-band channel that lets the host operating system talk to its own BMC using IPMI tools with no separate credentials. Leaving it on gives anyone with host root a direct path to the BMC.
- **Set unique credentials on every device.** Shared or default passwords remain the fastest route to a leaked RAKP hash.
- **Favor Redfish over IPMI where possible.** Turning off IPMI removes a large share of the attack surface, though the change should be enforced at the network level, not just in the management interface. Redfish is the newer standard for server management.

Alongside the disclosure, runZero released OOBscan, an open-source tool that runs these bypass techniques automatically. It is available on GitHub at

<https://github.com/runZeroInc/oobscan> [https://github.com/runZeroInc/oobscan].

“So you know, from our perspective, we kind of won,” Moore said. “Like the majority of IPMI devices in the world now, you can go from zero to full authentication to take over the boot process to then take over the host OS.”

Network Security[https://www.networkworld.com/network-security/] Security[https://www.networkworld.com/security/]

Networking[https://www.networkworld.com/networking/] Servers[https://www.networkworld.com/servers/]

Data Center[https://www.networkworld.com/data-center/]

About 

Policies 

More 

Our Network 



© 2026 FoundryCo, Inc. All Rights Reserved.